



Tabletop Exercise: Insider Theft of High-Net-Worth Client Data

Facilitation-ready cyber crisis exercise

Evaluation-integrated revision based on uploaded scenario and feedback

EXERCISE TYPE Discussion-based tabletop exercise

PRIMARY FOCUS Insider risk, client data confidentiality, evidence handling, legal/HR coordination

SUGGESTED DURATION 75-90 minutes

AUDIENCE Executive, operational, technical, legal, HR, privacy, compliance, client-facing leaders

GENERATED 13 July 2026

Confidential document. For internal distribution and authorized exercise use only.

Document Map

- Revision integration summary
- Introduction and exercise overview
- Scope, objectives, success measures, assumptions, and rules of engagement
- Participant roles and governance model
- Scenario summary, evidence model, and master timeline
- Phased injects with discussion questions, expected actions, and facilitator notes
- Decision points, impacts, audience prompts, and debrief guide
- Improvement actions, source scenario mapping, MITRE ATT&CK mapping, scorecard, glossary, and references

Facilitator use

This document is written as a combined participant and facilitator guide. Facilitator notes, evidence prompts, and expected actions are included after each inject. In a live session, facilitators may distribute only the inject text to participants and retain the notes and scorecard.

Revision Integration Summary

This version preserves the original insider-threat scenario structure while explicitly integrating the evaluation feedback. The most significant changes are intended to improve cyber accuracy, realism, decision pressure, and facilitation quality.

Dimension	Original score	Applied improvement
Realism	4.1	Added concrete but plausible telemetry: CRM export job, API audit trail, endpoint file creation, USB insertion, file-write evidence, DLP event, physical access, and HR offboarding context.
Coherence and consistency	4.0	Separated confirmed facts, suspected facts, unknowns, and facilitator-only information at every inject.
Cyber accuracy and MITRE ATT&CK	2.6	Constrained ATT&CK mapping to evidenced behavior, removed unsupported multi-tactic T1078 treatment, and added confidence levels and excluded-technique rationale.
Training value	4.4	Added concrete playbook checkpoints, decision criteria, evidence request prompts, and a scorecard.
Structural completeness	4.7	Added success measures, governance mechanics, RACI-style decision clarity, glossary, and facilitation checkpoints.

Key design principle applied

The exercise no longer treats suspected USB exfiltration, motive, or external exposure as known at the start. Participants must decide under uncertainty, preserve evidence before confrontation, and update classification as facts are confirmed.

Introduction

This tabletop exercise tests the organization's ability to detect, assess, contain, investigate, and manage an insider-driven theft of sensitive private-banking client information. The scenario centers on a departing relationship manager or equivalent client-facing employee who uses legitimate access to export an unusually large volume of client-book data and may attempt to copy it to unapproved removable media.

The exercise focuses on insider-risk detection, evidence preservation, legal and HR coordination, privacy and regulatory assessment, client-impact analysis, executive escalation, and communications control. It is not a technical live-fire exercise; participants should use existing policies, crisis structures, playbooks, and decision authorities.

Exercise Overview

Scenario title	Insider Theft of High-Net-Worth Client Data
Exercise type	Discussion-based tabletop exercise
Suggested duration	75-90 minutes, with optional 30-minute extended debrief
Primary audience	Executive leadership, CISO or delegate, SOC, Incident Response, Digital Forensics, Legal, HR, Privacy, Compliance, Client Relationship Management, Communications, IAM, Endpoint Engineering, Data Governance / DLP, and Business Line leadership
Scenario basis	Uploaded exercise scenario describing insider theft of high-net-worth customer data, enriched using the accompanying evaluation feedback.
Core risk themes	Legitimate-access misuse, abnormal export detection, removable media controls, legal defensibility, employee-rights considerations, client trust, jurisdictional notification analysis, and insider-risk governance.
Exercise outputs	Decision log, initial severity classification, evidence preservation plan, containment decision, notification decision framework, executive briefing outline, and after-action improvement plan.

Scope

The exercise covers the following activities and decision areas:

- Detection and triage of suspicious customer-data exports by a departing employee.

- Assessment of whether activity is normal business use, policy violation, insider threat, privacy incident, or confirmed breach.
- Preservation of application, database, endpoint, authentication, email, DLP, physical access, and HR/offboarding evidence.
- Containment of user access, workstation, removable media, cloud sessions, mailbox, collaboration tools, and customer-data systems.
- Coordination between Security, Legal, HR, Privacy, Compliance, business leadership, and client-facing teams.
- Decisions on employee engagement, access revocation, legal hold, device seizure, interview sequencing, and civil or criminal action.
- Client-impact analysis, regulatory notification assessment, law-enforcement considerations, and controlled communications.
- Recovery, monitoring for delayed misuse, lessons learned, and control improvement planning.

The exercise does not require participants to perform live technical remediation. Participants should describe how their real organization would execute the necessary steps, who has authority, what evidence is needed, and how decisions are documented.

Objectives

- 1 Recognize indicators of insider misuse involving legitimate access to sensitive client data.
- 2 Distinguish confirmed facts from hypotheses during a fast-moving insider investigation.
- 3 Assess severity, business impact, privacy exposure, and regulatory significance of potential high-net-worth client data theft.
- 4 Coordinate Security, Legal, HR, Privacy, Compliance, and business decisions before employee confrontation or disciplinary action.
- 5 Make defensible decisions on evidence preservation, legal hold, account containment, device acquisition, and chain of custody.
- 6 Evaluate client-notification, regulator-notification, contractual, confidentiality, and law-enforcement considerations.
- 7 Demonstrate clear executive escalation, board-ready briefing discipline, and consistent internal and external messaging.
- 8 Identify control gaps related to monitoring, offboarding, least privilege, removable media, data export approvals, and insider-risk governance.

Success Measures and Evaluation Criteria

Criterion	Successful performance looks like
First-hour triage	Incident owner assigned; severity initially classified; Security, Legal, HR, Privacy, Compliance, and business owner notified using agreed escalation paths.
Evidence preservation	Logs, endpoint data, export artifacts, HR records, mailbox/collaboration content, physical access records, and DLP events preserved before employee contact.
Fact discipline	Participants keep a visible distinction between confirmed, suspected, unknown, and facilitator-only details.
Containment decision	Access disablement, session revocation, device isolation, and offboarding suspension are decided using risk, legal defensibility, and evidence needs.
Governance clarity	SOC/IR owns technical containment; Legal/HR own employee process; Privacy/Compliance own notification analysis; Crisis Cell owns enterprise risk and messaging decisions.
Notification analysis	Participants use a jurisdictional notification matrix and data sensitivity assessment rather than notifying solely because an export occurred.
Communications control	Approved internal, executive, client-facing, regulator-facing, and media messaging channels are identified.
Lessons learned	Remediation owners, due dates, and control improvements are agreed in the after-action plan.

Assumptions

- The suspected employee is a relationship manager or equivalent client-facing role with legitimate access to private-banking client records.
- The employee is in the final week of employment and remains in normal offboarding status at exercise start.
- The customer repository is a private-banking client-book or CRM-like platform that supports bulk exports and produces audit logs.
- The organization has centralized logging for export jobs, identity events, endpoint activity, removable media events, DLP alerts, and email/collaboration activity.
- Legal, HR, Privacy, Compliance, SOC, IR, and executive representatives are available for urgent consultation.
- Jurisdiction-specific regulatory thresholds are intentionally not fixed in this generic version. Participants should apply their real notification and regulator-engagement matrix.
- Not every fact is known at the start. The facilitator will introduce additional evidence through injects.

Rules of Engagement

- This is a no-fault learning exercise.
- Use real organizational roles, processes, escalation paths, and resource constraints where possible.
- Treat scenario injects as credible unless later information changes them.
- Do not fight the scenario. Ask clarifying questions as you would during a real incident.
- Avoid prematurely declaring a data breach, criminal act, or notification trigger without the facts required by policy and law.
- Real-world incidents take priority over the exercise.
- All exercise discussion is confidential and should not be shared outside the approved audience.

Participant Roles and Governance Model

A key improvement in this version is explicit separation of operational, legal, HR, privacy, business, and crisis-management responsibilities. The exercise should test whether participants know who decides, who advises, and who executes.

Function	Primary exercise responsibilities	Decision authority / output
Executive / Crisis Leadership	Set risk appetite, approve enterprise crisis posture, review client and regulator strategy, brief board or senior leadership as required.	Approves enterprise-level response strategy, external messaging posture, and escalation to board-level governance.
CISO / Security Leadership	Own cyber incident classification, advise on containment risk, coordinate SOC/IR/DFIR, translate technical facts for executives.	Approves cyber response strategy within delegated authority and escalates material risk.
SOC / Incident Response	Triage alerts, preserve telemetry, validate export scope, coordinate technical containment, request forensic acquisition.	Executes technical containment and evidence collection; recommends severity changes.
Digital Forensics	Acquire endpoint image, analyze local staging, USB events, file hashes, browser/cloud activity, and chain of custody.	Produces forensic facts and confidence levels.
Legal Counsel	Establish privilege, advise on legal hold, employee interview, civil action, law enforcement, and notification obligations.	Controls legal strategy and privileged investigation boundaries.
HR / Employee Relations	Manage employee process, interview logistics, offboarding suspension, dignity and confidentiality, disciplinary action.	Owns employee engagement and employment action process with Legal.
Privacy / Data Protection	Classify affected data, evaluate privacy incident and breach thresholds, coordinate notification matrix.	Recommends privacy notification decisions based on facts and jurisdiction.
Compliance / Regulatory Affairs	Map regulatory reporting duties, prepare regulator-ready chronology, coordinate supervisory engagement.	Recommends regulator notification timing and content.
Business Line / Private Banking	Assess client impact, continuity of relationship management, client prioritization, client-facing scripts.	Owns client relationship response under approved messaging.
Communications	Prepare internal, client, media, and executive messaging; prevent inconsistent statements.	Publishes only approved messaging.
IAM / Endpoint / DLP Teams	Disable access, revoke sessions, preserve logs, block removable media, validate DLP events.	Execute technical actions directed by SOC/IR and Security leadership.

Decision Cell Operating Model

For this scenario, the facilitator should prompt participants to establish a cross-functional decision cell by Inject 2. The cell should include Security, Legal, HR, Privacy, Compliance, business ownership, and communications. The SOC/IR team should not be expected to make employment, client-notification, or regulator-notification decisions alone.

- SOC/IR decides and executes technical containment within delegated authority.
- Legal and HR decide the lawful employee engagement sequence.
- Privacy and Compliance decide the notification analysis process and recommend notification thresholds.
- Business leadership decides client prioritization and continuity actions under approved messaging.
- Executive/Crisis leadership approves enterprise-level risk decisions, external posture, and board escalation.

Scenario Summary

Monitoring identifies an unusually large export of high-net-worth client records performed by a departing employee during their notice period. Initial review indicates the export used legitimate credentials and may include records outside the employee's usual portfolio. Endpoint telemetry later shows local file staging and the connection of an unapproved removable storage device in the same time window.

The organization must determine whether the event is authorized business activity, a policy violation, attempted client-book poaching, a privacy incident, a material breach, or part of a broader compromise. The incident rapidly becomes a cross-functional matter involving confidentiality, employee rights, evidentiary preservation, client trust, regulatory

expectations, and potential civil or criminal action.

Evidence Model and Confidence Legend

Facilitators should actively require participants to label facts by confidence. This prevents early overreach, especially around motive, USB exfiltration, and external disclosure.

Label	Meaning	Example in this exercise
Confirmed	Supported by a reliable log, artifact, admission, forensic finding, or documented business record.	Bulk export job ID, account used, export timestamp, endpoint USB insertion event.
Suspected	Plausible and supported by partial telemetry or circumstantial evidence, but not yet proven.	Sensitive file copied to removable media before file hash comparison is complete.
Unknown	Not established yet; do not brief as fact.	Whether the data reached a competitor, client, public forum, or personal cloud account.
Facilitator-only	Information the facilitator may reveal later if participants ask the right questions or reach the correct phase.	Employee accepted a competitor role; USB serial number is linked to prior use.

Facilitator Technical Artifacts

Artifact	What it can show	When to release
CRM export audit log	User ID, export job ID, timestamp, fields exported, record count, filters used, source IP, MFA status.	Inject 1 if participants ask for application or database evidence.
IAM / SSO logs	Successful authentication from corporate-managed device; no impossible travel; no failed MFA storm.	Inject 1-2.
HR offboarding record	Notice period status, resignation date, manager approval state, competitor destination if known.	Inject 1-3, with HR/Legal involvement.
Endpoint EDR timeline	Local export file creation, process/user context, file path, USB insertion, file writes, hash values where available.	Inject 2 onward.
DLP / removable media alert	Policy rule triggered by sensitive data pattern and unapproved USB serial number.	Inject 2 onward.
Email / collaboration review	Potential personal email attempt, client-book references, or competitor-related communication.	Inject 3, under Legal direction.
Physical access logs	Badge activity, workstation location, office presence, printer area access.	Inject 2-4.
Dark web / external monitoring	No evidence of public posting at resolution; ongoing monitoring needed.	Inject 3-5.

Master Scenario Events List

Exercise time	Inject	Scenario development	Primary decision pressure
09:00	Inject 1 - Initial Detection	Bulk client-book export by departing employee is detected.	Classify, preserve evidence, notify first-hour stakeholders.
10:15	Inject 2 - Removable Media Indication	Endpoint telemetry shows local staging and unapproved USB connection.	Containment versus monitoring; Legal/HR interview sequence; device preservation.
11:30	Inject 3 - Motive and Scope Develop	Competitor role and client-book intent indicators emerge; no public leak confirmed.	Notification analysis, legal options, client segmentation, executive briefing.
13:00	Inject 4 - Evidence Confirmation and Decision Cell	File hash and endpoint data confirm local staging and USB transfer; external disclosure remains unknown.	Suspend offboarding, approve external posture, regulator/client decision framework.
Next business day / +72h	Inject 5 - Stabilization and Aftermath	Immediate access is revoked, devices preserved, monitoring continues, after-action work begins.	Final reports, remediation owners, ongoing misuse monitoring, lessons learned.

Inject 1 - Initial Detection

Exercise time	09:00
---------------	-------

Inject

Monitoring alerts show that a relationship manager in their final week of employment exported an unusually large volume of high-net-worth client records from the private-banking client-book platform. The export used the employee's legitimate account, passed MFA, and originated from a managed corporate laptop. Initial review shows the export contains records outside the employee's usual portfolio.

What participants know at this stage

Confidence	Details
Confirmed	- A named employee is in an offboarding / notice period. - A bulk export occurred from the private-banking client-book or CRM platform. - The export volume is materially above the employee's 90-day baseline. - The export used legitimate credentials from a managed corporate device. - Some records appear outside the employee's assigned client portfolio.
Suspected	- The activity may be unauthorized, but business justification has not yet been ruled out. - The exported data may include personal and portfolio-related information, but the field-level scope is still being validated.
Unknown	- Intent is unknown. - Destination of the exported data is unknown. - No removable media, cloud upload, or external disclosure has yet been confirmed. - Regulatory notification thresholds have not yet been determined.

Discussion questions

- How should the incident be classified in the first hour: insider-risk event, privacy incident, cyber incident, HR matter, or all of these?
- What immediate evidence must be preserved before any employee contact?
- Who must be notified in the first hour, and who should not yet be notified?
- What business justification checks are appropriate before escalation?
- What threshold triggers executive visibility?
- How will participants document what is fact versus hypothesis?

Expected actions

- Open a priority insider-risk / security incident and assign a single incident owner.
- Preserve CRM export logs, database query logs, SSO/MFA logs, endpoint telemetry, DLP alerts, email/collaboration logs, and HR offboarding records.
- Validate export scope: record count, fields exported, client segments, jurisdictions, and whether records exceed role-based access expectations.
- Notify Legal and HR before any confrontation, interview, or disciplinary action.
- Engage Privacy and Compliance for preliminary impact and notification triage.
- Review manager approvals, recent tasking, client portfolio assignments, and business justification.
- Establish a decision log and privilege protocol for sensitive investigation material.

Evidence prompts for facilitator

- If asked, provide a sample CRM export log: export job PB-EXP-2026-0713-0034, 764 records, CSV format, fields including name, contact details, relationship notes, risk category, holdings summary, and relationship manager assignment.

- If asked, provide SSO detail: successful MFA, normal device, no evidence of credential theft at this stage.
- If asked, provide baseline anomaly: employee normally exports fewer than 25 records per week; this export is over 30 times normal volume.

Facilitation checkpoint

By the end of Inject 1, participants should name the incident owner, identify first-hour stakeholders, and list evidence to preserve before employee engagement.

Facilitator notes

Strong teams should avoid immediately framing the case as a confirmed breach or criminal act. The desired behavior is rapid preservation, structured triage, and early Legal/HR/Privacy involvement while keeping the employee unaware until containment and evidence strategy are agreed.

Inject 2 - Removable Media Indication

Exercise time	10:15
---------------	-------

Inject

Endpoint telemetry shows that an unapproved external storage device was connected to the employee's workstation within minutes of the export. The EDR timeline also shows the exported CSV being written to a local downloads directory and then accessed by a file copy process. Investigators cannot yet prove that the full sensitive file was successfully copied to the removable device.

What participants know at this stage

Confidence	Details
Confirmed	- A USB/removable storage device was connected to the employee's workstation in the same time window as the export. - The exported CSV was created locally on the workstation. - The endpoint agent recorded file access and file-copy activity. - The employee still has active access to some corporate systems and may be on site or remote.
Suspected	- The export file may have been copied to the removable device. - There is a risk of evidence destruction, additional copying, or onward disclosure. - The employee may have a non-malicious explanation, but the timing and data volume are abnormal.
Unknown	- The exact files written to removable media are not yet hash-confirmed. - It is unknown whether the USB device is still connected, in the employee's possession, or recoverable. - It is unknown whether any data left the organization through email, cloud storage, printing, or messaging.

Discussion questions

- Do you revoke access immediately, continue covert monitoring briefly, or use a hybrid approach?
- Should departure processing be suspended now?
- What should happen if the employee is on site versus remote?
- Who approves laptop isolation, account disablement, session revocation, and device seizure?
- How should HR and Legal coordinate an interview without compromising evidence or employee rights?
- What chain-of-custody steps are required for the laptop, removable media, and forensic images?
- What business continuity issues arise if the employee manages active high-value clients?

Expected actions

- Convene a cross-functional decision cell including Security, Legal, HR, Privacy, Compliance, business ownership, and Communications as needed.
- Decide containment strategy: immediate disablement, staged disablement, controlled monitoring, or manager-led intervention under Legal/HR guidance.
- Preserve endpoint evidence, including memory where appropriate, disk image, USB serial number, file system metadata, EDR events, and DLP logs.
- Place the employee account, mailbox, collaboration content, export artifacts, and endpoint under legal hold as appropriate.
- Review USB control policy, exceptions, device inventory, and prior use of the same USB serial number.
- Check for email forwarding, personal cloud uploads, printing, screenshots, messaging apps, and unusual remote access.
- Prepare a client coverage plan in case the employee's access must be removed immediately.

Evidence prompts for facilitator

- If participants choose immediate access revocation, ask how they will preserve active sessions, tokens, and endpoint evidence without remote wipe side effects.
- If participants choose monitoring, ask what additional loss threshold would end monitoring.
- If asked for endpoint details, reveal USB serial SN-4C92-EXERCISE connected at 03:21 and file PB_Client_Export_Q3.csv created at 03:18.
- If asked for DLP detail, reveal a rule match for high-net-worth client identifiers but note that the agent did not yet complete file-content verification.

Facilitation checkpoint

By the end of Inject 2, the group should have a documented containment decision, a Legal/HR employee engagement plan, and a chain-of-custody plan.

Facilitator notes

This inject is designed to test the tradeoff between evidence collection and preventing further data loss. Strong responses should avoid the common failure mode of treating the SOC as the owner of HR discipline or client notification decisions. The SOC should own technical facts and containment recommendations; Legal/HR and executive governance should own employee and enterprise decisions.

Inject 3 - Intent and Scope Develop

Exercise time	11:30
---------------	-------

Inject

A privileged review led by Legal finds that the employee has accepted a role with a competitor. Internal messages and notes indicate the employee discussed taking 'relationship history' and 'client context' to support transition planning. A blocked personal-email attempt containing a spreadsheet with a similar file name is also identified. There is still no evidence that client data has been publicly posted, sold, or used to contact clients.

What participants know at this stage

Confidence	Details
Confirmed	- The employee has accepted a role with a competitor. - Messages suggest possible intent to use relationship or client-book information after departure. - A DLP control blocked a personal-email attempt involving a similarly named spreadsheet. - No public leak, sale, or confirmed client solicitation has been identified at this point.
Suspected	- The likely motive may involve client solicitation or competitive misuse. - The incident may involve attempted exfiltration through more than one channel. - The blocked email may contain the same data, a subset, or a benign file with a similar name.
Unknown	- The full data set and final external destination remain unknown. - It is not yet confirmed whether any client has been contacted. - Notification thresholds remain dependent on data scope, jurisdiction, and likelihood of misuse.

Discussion questions

- Does this trigger formal breach notification analysis now, or only after confirmed external disclosure?
- What legal actions should be considered immediately: preservation demand, cease-and-desist, injunction, civil action, or law-enforcement referral?
- Should the organization contact the employee's new employer at this stage?
- Which client segments should be prioritized for impact analysis?
- How should executives be briefed without overstating facts?
- How do you protect privilege while ensuring operational teams have enough facts to act?
- What monitoring should begin for client outreach, suspicious logins, competitor contact, or dark web references?

Expected actions

- Conduct a formal privacy/breach and regulatory notification assessment under Legal/Privacy/Compliance coordination.
- Segment potentially affected clients by data sensitivity, residency, relationship value, regulatory regime, and vulnerability.
- Prepare an executive briefing with separate sections for confirmed facts, suspected facts, unknowns, decisions needed, and recommended next actions.
- Consider preservation demand, cease-and-desist, civil litigation hold, or law-enforcement options with counsel.
- Increase monitoring for suspicious client outreach, customer complaints, unusual access to client accounts, and external references.
- Prepare relationship manager instructions and FAQs, but do not release client messaging until approved.
- Ensure investigation material remains appropriately privileged and need-to-know.

Evidence prompts for facilitator

- If asked, reveal that Legal has authorized a targeted review of business messages and email under policy.
- If participants ask about the blocked email, reveal that DLP blocked transmission to a personal webmail address at 03:33; content verification is pending.
- If participants ask about clients, provide a preliminary affected population: several hundred HNW clients across multiple residency categories, with a small subset designated ultra-high sensitivity due to public profile or family-office status.

Facilitation checkpoint

By the end of Inject 3, participants should have a breach-notification assessment owner, a draft executive briefing structure, and a client segmentation approach.

Facilitator notes

This stage should shift the discussion beyond IT containment. Strong groups will distinguish between legal theory and proven facts, avoid unapproved contact with the competitor, and prepare leadership for decisions without forcing premature notification.

Inject 4 - Evidence Confirmation and Decision Cell

Exercise time	13:00
---------------	-------

Inject

Forensics confirms that the exported file hash matches a file staged locally on the workstation. The endpoint timeline now shows a write of the same file to an unapproved removable device path. The removable device itself has not yet been recovered. Investigators estimate that 684 high-net-worth client records were exposed to unauthorized copying, including contact details, relationship notes, account relationship information, and portfolio-summary fields. No full account credentials, passwords, or transaction authorization tokens are present in the export.

What participants know at this stage

Confidence	Details
Confirmed	- The exported file was staged locally on the employee workstation. - Endpoint telemetry confirms a file write to an unapproved removable media path. - The affected data set includes 684 high-net-worth client records. - The records include sensitive relationship and portfolio-summary information but no passwords or transaction authorization tokens. - The removable device has not yet been recovered.
Suspected	- The data is likely in the employee's possession outside approved systems. - There is risk of client poaching, confidentiality breach, litigation, and regulatory scrutiny. - External disclosure beyond the removable device remains possible but unconfirmed.
Unknown	- Whether the data has reached the competitor is unknown. - Whether any client has been solicited is unknown. - Jurisdiction-specific notification thresholds require final Legal/Privacy/Compliance analysis.

Discussion questions

- Who has final authority for client notification and regulator outreach?
- What threshold determines whether clients are contacted now versus later?
- Should offboarding completion be suspended and all access permanently revoked?
- How should relationship managers respond if clients mention unusual contact or the departing employee?
- What external statement, if any, is approved?
- Should law enforcement be contacted now, and who makes that recommendation?
- How will the organization prevent inconsistent messaging across Security, HR, Legal, Compliance, and business leaders?

Expected actions

- Formally classify the incident using the organization's cyber, privacy, legal, and crisis severity criteria.
- Revoke access, terminate active sessions, disable tokens, and preserve account state as directed.
- Suspend offboarding completion and preserve all assigned devices and access records.
- Finalize legal hold, forensic acquisition, evidence custody, and case-management steps.
- Approve a client-risk decision framework and notification criteria.
- Prepare a regulator-ready chronology: what happened, when it was detected, data involved, containment completed, and next steps.
- Prepare approved talking points for executives, client relationship teams, HR, and communications.
- Decide whether to pursue preservation demand, civil action, law enforcement, or notification to the new employer.

Evidence prompts for facilitator

- If participants ask for file proof, provide hash match between CRM export and staged local file.
- If participants ask about USB confidence, confirm file write to removable media path and USB serial number, but state the physical device is not recovered.
- If participants ask about data fields, provide a field list and note what is not included to prevent overstatement.
- If participants ask about clients, provide a top-25 client sensitivity list for prioritization but keep identities fictitious.

Facilitation checkpoint

By the end of Inject 4, the organization should have an approved containment state, notification decision framework, external communications posture, and regulator-ready chronology.

Facilitator notes

Watch for governance clarity. Participants should state who decides, who advises, and who executes. They should also separate 'client data copied to USB' from 'client data publicly leaked' because the legal and notification consequences may differ by jurisdiction and evidence.

Inject 5 - Stabilization and Aftermath

Exercise time	Next business day / +72 hours
---------------	-------------------------------

Inject

The employee's access has been revoked, the corporate laptop has been forensically preserved, and immediate technical containment is complete. The personal removable device has not been recovered, and Legal has issued preservation demands. External monitoring has not identified public posting or sale of the client data. The organization must finalize notifications, monitor for downstream misuse, complete reporting, and assign remediation owners.

What participants know at this stage

Confidence	Details
Confirmed	- Corporate account access and active sessions have been revoked. - The corporate laptop and relevant logs have been preserved. - No public posting, dark web listing, or confirmed client solicitation has been detected to date. - Legal actions and preservation demands are underway.
Suspected	- The data may still be outside approved custody because the removable device is not recovered. - Delayed misuse remains possible. - Regulator or client notification may still be required depending on legal analysis and jurisdiction.
Unknown	- Final external destination and use of the data remain unknown. - Final client notification and regulator reporting decisions are pending governance approval. - Long-term control remediation has not yet been implemented.

Discussion questions

- What are the next steps over the next 24 hours, 7 days, and 30 days?
- What post-incident reporting is required to executives, board committees, regulators, clients, and insurers?
- What control gaps most likely enabled the incident?
- How will the organization monitor for delayed misuse of the stolen client information?
- How should client-facing teams handle rumors or direct client questions?
- What evidence must be retained, for how long, and under whose custody?
- What improvements are needed in offboarding and insider-risk governance?

Expected actions

- Produce an executive after-action summary and decision log.
- Complete privacy, legal, regulatory, contractual, and client-notification assessments.
- Continue monitoring for dark web exposure, client complaints, suspicious outreach, competitor contact patterns, and anomalous client-account activity.
- Review removable-media controls, abnormal export alerts, access governance, offboarding triggers, and manager approvals.
- Update insider-risk playbooks, HR/legal engagement procedures, and evidence preservation checklists.
- Assign remediation owners, dates, and governance reporting path.
- Schedule a lessons-learned review and track actions to closure.

Evidence prompts for facilitator

- If participants ask about monitoring, suggest tracking client complaints, unusual contact reports, known competitor outreach, and external data exposure references for at least 30-90 days according to policy.

- If participants ask about reporting, require a regulator-ready chronology and a separate privileged legal analysis.
- If participants ask about controls, prompt for preventive, detective, and corrective improvements.

Facilitation checkpoint

By the end of Inject 5, participants should have an after-action report structure, monitoring plan, and remediation backlog with owners.

Facilitator notes

This final phase should test whether the organization can turn containment into durable risk reduction. Strong teams will not close the incident simply because access was revoked; they will track legal, privacy, client, regulatory, and control-remediation workstreams to closure.

Decision Points

Decision	Key question	Minimum evidence or input needed
1. Classification	Is this an HR matter, policy violation, insider threat, privacy incident, cyber incident, or confirmed breach?	Export logs, data class, intent indicators, policy thresholds, legal/privacy guidance.
2. Containment	Should access be disabled immediately or should monitoring continue briefly?	Current access status, risk of further loss, available evidence, Legal/HR employee process.
3. Employee action	Continue offboarding, suspend offboarding, interview, administrative leave, or termination?	HR policy, Legal advice, evidence maturity, business continuity plan.
4. Evidence handling	When and how do we seize devices and preserve media?	Chain-of-custody process, location of employee, device inventory, endpoint state.
5. Client impact	Which clients are affected and how severe is the data exposure?	Record list, field-level data classification, client sensitivity, jurisdiction/residency.
6. Client notification	Who is contacted, when, and with what message?	Legal/privacy assessment, likelihood of misuse, regulator expectations, approved talking points.
7. Regulatory engagement	Immediate notice, preliminary advisory, or post-investigation report?	Notification matrix, jurisdictional thresholds, materiality, executive approval.
8. Legal response	Civil action, preservation demand, law-enforcement referral, new employer contact, or combined approach?	Counsel advice, evidence confidence, business risk, employment constraints.
9. Communications	What is approved for internal, client-facing, media, and regulator communications?	Facts known, message owner, spokesperson, escalation and approval path.

Business and Technical Impact Considerations

Business impacts

- Loss of trust among high-net-worth and ultra-high-net-worth clients.
- Client attrition and competitive harm from relationship or portfolio context misuse.
- Confidentiality, fiduciary, contractual, and privacy exposure.
- Regulatory scrutiny and potential supervisory remediation.
- Litigation, employment dispute, civil injunction, or law-enforcement involvement.
- Reputational impact in a relationship-driven private-banking business.
- Operational disruption if key client relationships must be reassigned quickly.

Technical and control impacts

- Abnormal export detection may not be tuned to notice-period or client-facing roles.
- Role entitlements may allow bulk access outside portfolio need.
- Data export approvals may not require manager justification, purpose, or expiry.
- Removable media may be allowed or logged but not blocked.
- Endpoint telemetry may identify USB insertion but not reliably capture file contents.
- Offboarding may not trigger enhanced monitoring or dynamic access reduction.
- DLP may block email but miss removable-media or local staging activity.
- Evidence gaps may arise if logs have short retention or inconsistent time synchronization.

Facilitator Prompts by Audience

Audience	Prompts
Executive / Crisis Leadership	- What makes this an enterprise crisis rather than an HR-led matter? - What would the Board expect to know in the first briefing? - What is your risk appetite for early client notification when external use is not confirmed? - What information do you need to approve regulator or law-enforcement engagement?
Operational / Control Functions	- How are Legal, HR, Privacy, Compliance, Security, and business synchronized in the first four hours? - Which records should be privileged, and who controls distribution? - How do you document decisions so they are defensible later? - How do you prevent accidental tipping off before evidence is preserved?
Technical Teams	- What telemetry confirms export volume, local staging, USB insertion, and file-write activity? - What data sources establish whether personal email, cloud upload, printing, or messaging occurred? - How do you preserve volatile and persistent evidence without remote wipe or token revocation side effects? - Which controls would have blocked or alerted on this earlier?
Legal / HR	- What is the interview sequence? - What is the threshold for administrative leave or termination? - What legal hold and preservation instructions are needed? - How do you balance confidentiality, employee rights, and urgent containment?
Privacy / Compliance	- What notification matrix applies by client residency and data class? - What is the difference between unauthorized access, unauthorized acquisition, and confirmed external disclosure in your policy? - What regulator chronology is needed? - Who approves preliminary regulator outreach?
Client Relationship / Communications	- How will client-facing staff answer questions without speculating? - Which clients are prioritized for relationship management outreach if notification is approved? - What messages are off-limits until Legal and Communications approve them? - How are inconsistent local messages prevented?

Expected Good Practices

- Use predefined insider-risk and privacy incident criteria for severity classification.
- Preserve evidence before employee contact, access changes that could destroy artifacts, or device wipe actions.
- Engage Legal and HR before confrontation or disciplinary action.
- Create a single decision log with time, owner, rationale, facts relied upon, and open assumptions.
- Use a fact/suspected/unknown briefing format for executives.
- Separate technical containment decisions from client-notification and employment decisions.
- Base notification decisions on data class, jurisdiction, likelihood of misuse, and legal obligations.
- Maintain chain of custody for laptop, removable media, logs, and exported files.
- Prepare client-facing and internal communications before rumors or client inquiries emerge.
- Translate lessons learned into control owners, due dates, and governance reporting.

Debrief / Lessons Learned

Use the final 10-15 minutes to discuss what worked, what was unclear, and which improvements have the highest risk-reduction value. Capture action owners and due dates.

Debrief questions

- What did the team classify correctly, and what would have been misclassified?
- Where were roles or decision authorities unclear?
- Were Legal, HR, Privacy, and Compliance engaged early enough?

- Did participants preserve evidence before containment or employee engagement?
- Would current tooling detect bulk export, local staging, USB copy, personal email, cloud upload, and printing?
- Are offboarding controls proportionate for high-risk roles?
- Can the organization produce a regulator-ready chronology quickly?
- What would you change in the next 30 days?

Suggested Improvement Actions

Control area	Suggested improvement	Owner candidates
Offboarding controls	Implement risk-based access reduction and enhanced monitoring for departing employees in sensitive client-facing or privileged roles.	HR, IAM, Business Owner, Security
Bulk export governance	Require purpose, approval, logging, and enhanced review for bulk exports of client data; alert on exports outside portfolio boundaries.	Data Governance, CRM Owner, Security
Insider-risk analytics	Correlate HR notice-period events, abnormal exports, USB events, personal email attempts, and unusual client-record access.	Insider Risk, SOC, HR, Privacy
Removable media	Block unapproved USB storage by default; maintain exception inventory; alert on sensitive file writes to removable media.	Endpoint Engineering, DLP, SOC
Least privilege	Review portfolio-based entitlements, privileged access, and admin roles for client-data repositories.	IAM, Business Owner, Compliance
Evidence readiness	Predefine chain-of-custody steps, forensic acquisition triggers, and legal hold templates for insider cases.	Legal, IR, DFIR, HR
Communications	Pre-build client, executive, regulator, and internal talking-point templates with approval workflows.	Communications, Legal, Compliance, Business
Testing	Run a follow-up exercise focused on technical evidence recovery and notification decision-making.	Crisis Management, Security, Privacy

Mapping to Source Scenario Elements

This revised exercise is derived from the uploaded exercise scenario and evaluation feedback. It preserves the core STIX-like scenario elements while adding operational detail and confidence labels.

Source element	How reflected in this exercise
Financial-services participant organization	Private-banking / high-net-worth client-data context with executive, legal, privacy, compliance, and client relationship impacts.
Departing insider with legitimate access	Relationship manager in notice period using legitimate credentials and managed device.
Sensitive client-book data	CRM/client-book export with client contact, relationship notes, account relationship, and portfolio-summary information.
Unapproved external storage device	Endpoint telemetry and DLP events introduce suspected USB activity in Inject 2; evidence becomes stronger in Inject 4.
Abnormal export alerting	CRM export audit and baseline deviation anchor the initial detection.
Cross-functional insider case management	Decision cell, RACI model, Legal/HR coordination, notification analysis, and executive briefing mechanics.
Legal hold, client risk, and law-enforcement/civil action decisions	Included as structured decision points and inject discussion prompts.

MITRE ATT&CK Mapping

The mapping below is intentionally evidence-constrained. It identifies what is confirmed by the scenario, what is suspected until later injects, and what should not be mapped without additional evidence. This corrects the prior overbroad treatment of Valid Accounts and avoids implying a malware-style intrusion chain where the scenario is primarily legitimate-access insider misuse.

Primary scenario mapping

Confidence	Tactic	Technique	Scenario evidence and facilitator guidance
Confirmed	Collection	T1213.004 - Data from Information Repositories: Customer Relationship Management Software	Bulk export from a private-banking client-book / CRM-like repository. Use this as the primary collection technique because the evidence centers on customer relationship data mined from a customer repository.
Confirmed by Inject 4; suspected earlier	Collection	T1074.001 - Data Staged: Local Data Staging	Endpoint evidence shows the exported file was staged locally before removable-media activity. Before Inject 4, treat this as suspected because local file creation alone does not prove exfiltration.
Confirmed by Inject 4; suspected earlier	Exfiltration	T1052.001 - Exfiltration Over Physical Medium: Exfiltration over USB	USB connection and later file-write evidence support USB exfiltration. Until file-write evidence is revealed, participants should treat USB exfiltration as suspected, not confirmed.
Parent technique	Exfiltration	T1052 - Exfiltration Over Physical Medium	Use the parent technique to summarize the removable-media exfiltration path. Do not double-count it separately from T1052.001 in scoring.

Contextual or excluded mapping

Technique	Treatment	Rationale
T1078 - Valid Accounts	Contextual only; do not score as Initial Access, Persistence, Privilege Escalation, or Defense Evasion in this scenario.	The employee used their own authorized account. There is no evidence of stolen credentials, unauthorized login, persistence, privilege escalation, or credential-based intrusion. Discuss IAM, least privilege, and anomaly monitoring instead.
T1560 - Archive Collected Data	Excluded unless later forensic artifacts show compression or archiving.	No ZIP/RAR/7z/archive creation is in the base evidence. Do not imply it.
T1083 - File and Directory Discovery	Excluded unless host or repository discovery commands are observed.	The scenario involves a targeted export from a known repository, not demonstrated discovery behavior.
T1041 - Exfiltration Over C2 Channel	Excluded.	No command-and-control channel, malware, or network exfiltration path is evidenced.
Credential Access techniques	Excluded.	No credential theft, token theft, phishing, or credential dumping is evidenced.

ATT&CK-informed detections and data sources to discuss

- CRM / client-book audit logs: high-volume exports, fields exported, records outside portfolio, export format, source IP, and export job ID.
- Identity logs: successful authentication, MFA status, device trust, impossible travel, session duration, and privilege context.
- Endpoint telemetry: file creation, local staging directory, file hash, removable media insertion, USB serial number, process responsible for copy, and volume writes.
- DLP telemetry: sensitive data fingerprints, blocked personal email, removable-media rule match, and policy exceptions.
- Email/collaboration logs: personal email attempts, external forwarding, competitor-related messages, and suspicious sharing.
- Physical and print telemetry: badge activity, printer logs, workspace access, and visitor logs.
- External monitoring: dark web references, client complaints, unusual outreach, and competitor-contact patterns.

Facilitator Scorecard

Use this scorecard during the exercise or immediately after the debrief. Rate each capability from 1 to 5: 1 = not demonstrated, 2 = partially demonstrated, 3 = adequate, 4 = strong, 5 = mature and repeatable.

Capability	1-5 rating	Evidence / observations
Initial classification and escalation		
Fact discipline: confirmed vs suspected vs unknown		
Evidence preservation and chain of custody		
Legal and HR coordination before employee contact		
Technical containment decision quality		
Client impact and data-scope analysis		
Privacy and regulatory notification analysis		
Executive briefing and board-readiness		
Client-facing and internal communications control		
After-action remediation ownership		

Observer notes template

Observation area	Notes
Strong practices observed	
Decision bottlenecks	
Unclear roles or authorities	
Evidence gaps	
Policy or playbook gaps	
Immediate remediation actions	
30-day follow-up actions	

Glossary

Acronym / term	Meaning
CRM	Customer Relationship Management platform or client-book repository used to manage client relationship data.
DLP	Data Loss Prevention controls that monitor, block, or alert on sensitive data movement.
EDR	Endpoint Detection and Response telemetry from laptops, workstations, and servers.
HNW / UHNW	High-net-worth / ultra-high-net-worth client categories.
IAM	Identity and Access Management.
IR / DFIR	Incident Response / Digital Forensics and Incident Response.
Legal hold	Instruction and process to preserve potentially relevant evidence for legal, regulatory, or investigation purposes.
MFA	Multi-factor authentication.
RM	Relationship manager or equivalent client-facing employee.
SIEM	Security Information and Event Management platform used for centralized logging and alerting.
STIX	Structured Threat Information Expression, a standardized format for cyber threat intelligence.
USB / removable media	External storage such as USB thumb drives, external hard drives, or similar devices.

References Consulted

References are included for exercise design and ATT&CK alignment. Organizations should replace generic legal/regulatory references with jurisdiction-specific requirements and internal policies.

Reference	Use in this exercise
Uploaded exercise source: test_06.pdf	Scenario structure, original injects, objectives, scope, and insider-threat premise.
Uploaded evaluation feedback: test_06_eval.json	Revision priorities: realism, fact separation, technical specificity, ATT&CK accuracy, success measures, and governance checkpoints.
MITRE ATT&CK T1213.004 - Data from Information Repositories: CRM Software	Primary collection mapping for customer/client repository export.
MITRE ATT&CK T1074.001 - Local Data Staging	Conditional/confirmed staging mapping after endpoint evidence.
MITRE ATT&CK T1052.001 - Exfiltration over USB	Removable-media exfiltration mapping, suspected early and confirmed only when file-write evidence is available.
MITRE ATT&CK T1052 - Exfiltration Over Physical Medium	Parent technique for physical-media exfiltration.
MITRE ATT&CK T1078 - Valid Accounts	Used as contextual discussion only; not counted as a primary intrusion technique in this insider scenario.
MITRE ATT&CK DET0550, DET0261, DET0220	Detection strategy alignment for CRM access, local staging, and USB exfiltration discussions.